

DATE: 08/03/2026

Information Security

Assignment #2

NAME: M-Abdullah

Course Code: CYC232

Reg No# FA24-BSE-042

{ Section-A }

(1)

Authentication is used to verify the identity of a user. There are three main factors of authentication.

- i) Something you know: Includes passwords, secret questions or PINs.
- ii) Something you have: Includes OTP, smart cards, mobile devices etc.
- iii) Something you are: Includes biometric features like fingerprints or face recognition.

Using multiple factors together, called multi-factor authentication, provides stronger security in online systems.

(2)

Password ~~ag~~ guessing attacks happen when users choose weak passwords, e.g. password like "123456" or their name.

Attackers use brute force or dictionary attacks to try common passwords until they get access.

Password bias

means users prefer easy & memorable passwords, which makes guessing easy. Without strong password policy or login limits, systems become vulnerable to such attacks.

(3)

Biometric authentication uses physical features like Fingerprint, Face or iris to verify identity. It is secure but it may cause privacy concern if data is stolen.

Token-based authentication uses devices like smart-cards or OTP apps. It is easier to use and can be replaced, but tokens can be lost or stolen.

Security: Biometric methods give higher security while token-based are $\neq$ more practical in daily use. Use both together for better protection.

(4)

Kerberos uses a trusted server called the Key Distribution Centre (KDC).

First, user logs in and requests authentication from the KDC.

The KDC verifies the user and sends a Ticket Granting Ticket (TGT). The user then sends the TGT to request a server ticket for a specific server. Finally, the

Service ticket is used to access the system without sending the password again.

(5)

Kerberos uses symmetric key encryption. The KDC acts as a trusted third party service and share secret keys with both users and servers. When a user requests access, the KDC creates encrypted tickets using these keys, because only the KDC and the server know the key, attackers cannot read the ticket. This method provides secure authentication without sending passwords.

(6)

Risks:

- i) If one password is stolen, the attacker can access all connected services.
- ii) Another risk is system failure, because if the SSO-server stops, user cannot log-in anywhere.

Mitigation Strategies:

- i) Use multi-factor authentication
- ii) Strong passwords and login monitoring.
- iii) Session timeout.
- iv) Access control.

DATE: / /

(7)

Authentication Type	Security level	Vulnerabilities Mitigated	Common Threats Remaining
Simple Password	Low	Basic unauthorized access	Guessing attacks.
Hashed Password	Medium	Password storage theft	Brute force
Salted Hash	High	Rainbow table attack	Weak password
Multi-factor Auth	Very High	Password theft	Phishing

(8)

Threat Agents: Those people or systems that try to break authentication security.

Internal T-Agents: Includes employees, admins, or users who misuse their access.

External T-Agents: Include hackers, attackers or malware from outside the organization.

Understanding threat agents helps in designing better security systems.

DATE: / /

(9)

Attacks:-

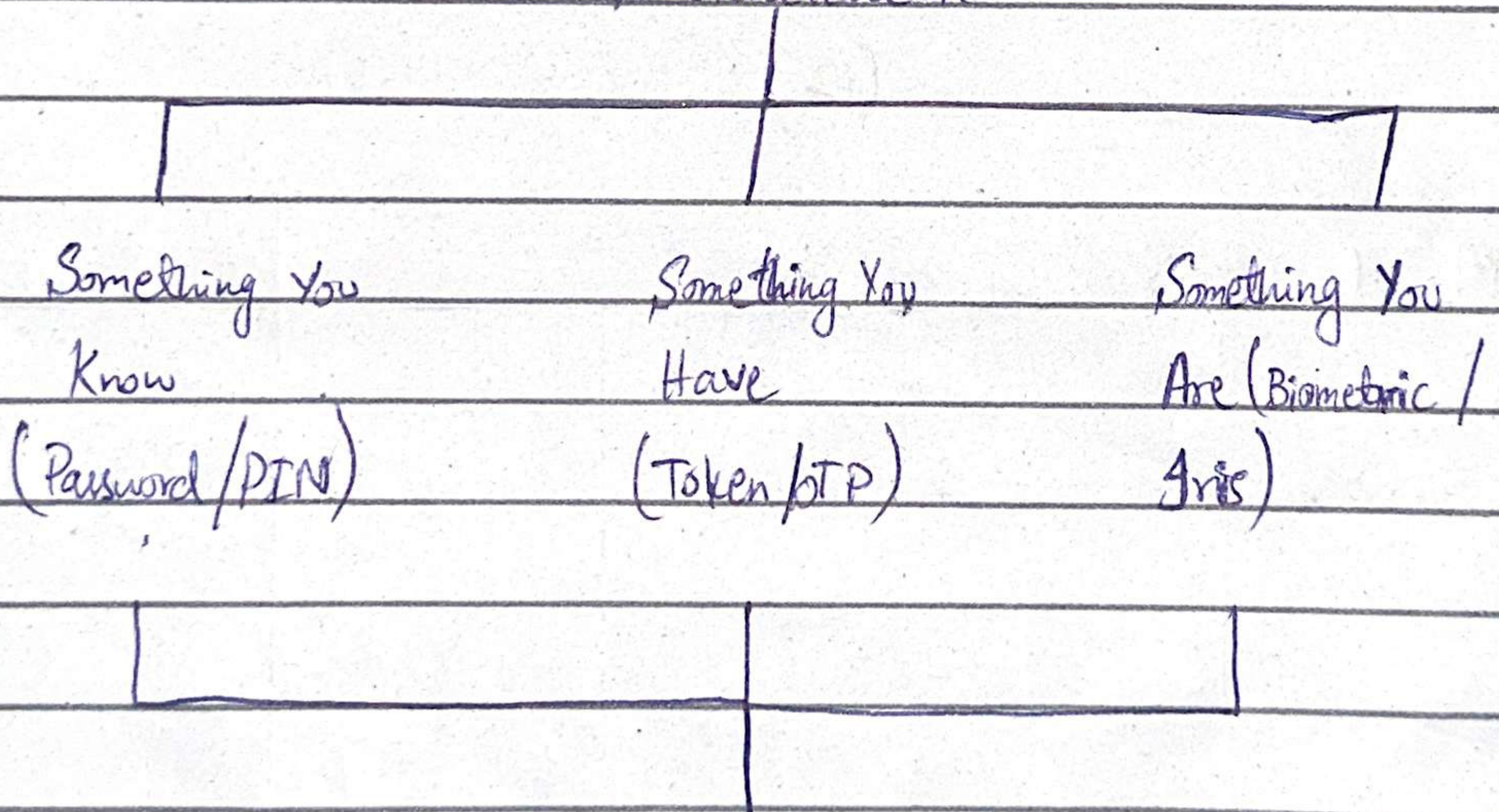
- i) Credential stuffing, where stolen passwords from other sites are reused.
- ii) Another attack is Phishing, where employees enter password on fake websites.

Preventive Measures:

- i) Strong Password and multifactor authentication.
- ii) Limiting attempts and login monitoring.

(10)

Authentication



MFA
(Combination of All)

{Section B}

(11)

Access control is important for protecting company's data, systems and resources from unauthorized users. Business needs access-control to maintain confidentiality, integrity and availability of information. It helps to follow security policies.

Human behavior is critical because users may share passwords, ignore rules or misuse access rights. Therefore, proper training and strict policies are required to make it effective.

(12)

Model	Use Case	Pros	Cons	Threat Risk
DAC	Small systems	Flexible	Weak security	Insider misuse
MAC	Military / Govt	Very secure	Hard to manage	Low
RBAC	Companies	Easy to Manage	Role errors	Medium
ABAC	Cloud / modern Apps	Very Flexible	Complex	Medium

(13)

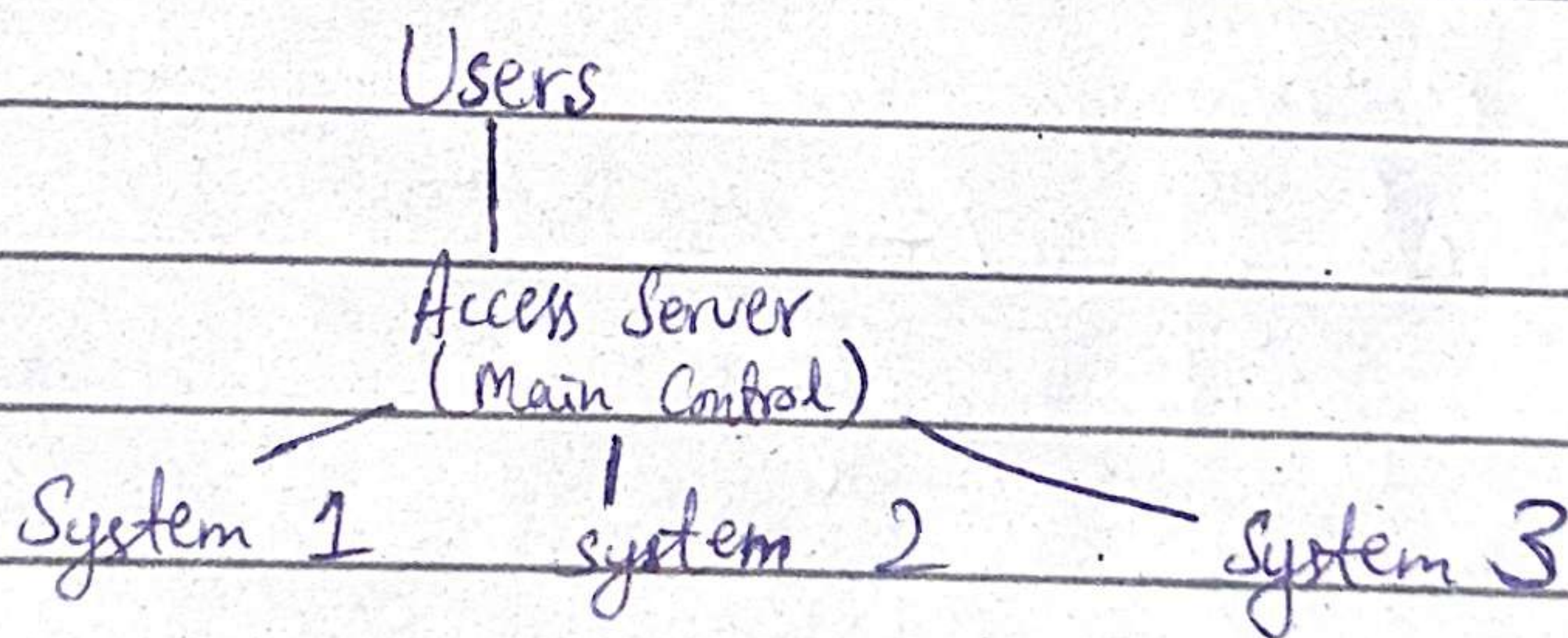
ACL: An Access Controlled list is a list of permissions attached to a file or system resource.

ACE: Each entry in the list is called Access Control Entry (ACE). It defines which user or group can read, write or execute a file.

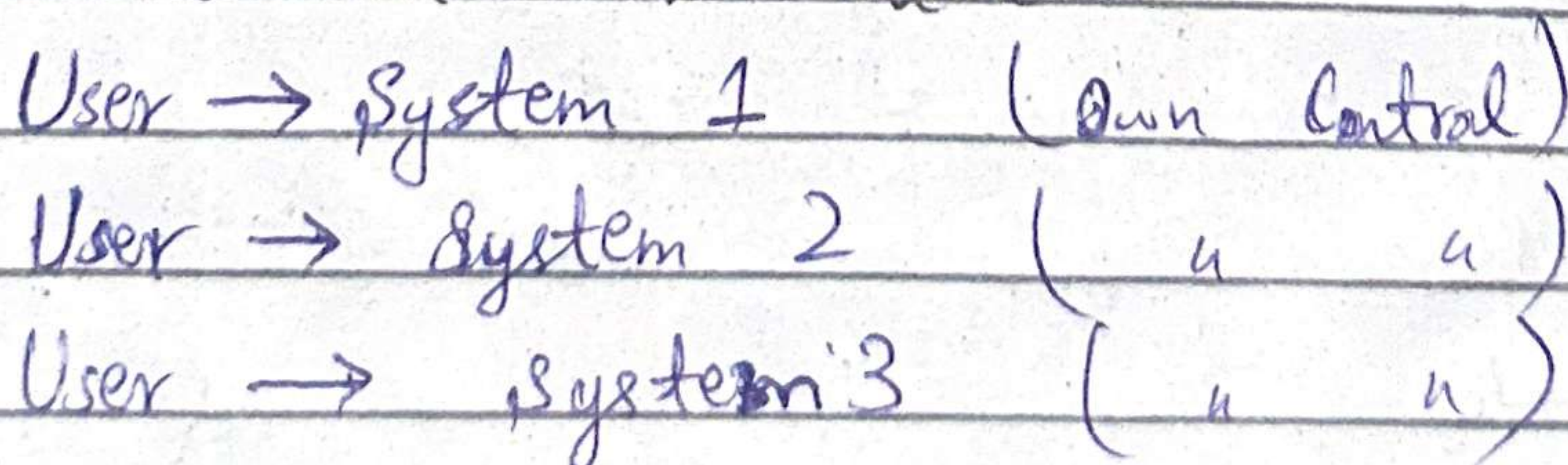
If ACL is misconfigured incorrectly, unauthorized users may get ~~the~~ access to ~~sent~~ sensitive data. Proper configuration and regular checking are needed to prevent security issues.

(14)

Centralized Access Control:



Decentralized Access Control:



(15)

Risk-Adaptive Access Control changes access based on risk-level. It checks user location, device and behaviour before giving access. In this way, it helps ^{protect} systems from dynamic and modern threats. R~~A~~AC is useful in cloud and enterprise environments.

(16)

If an employee misuses file access, it means access control failed.

Reasons include:

- i) Too many permissions
- ii) lack of monitoring.

Preventions include:

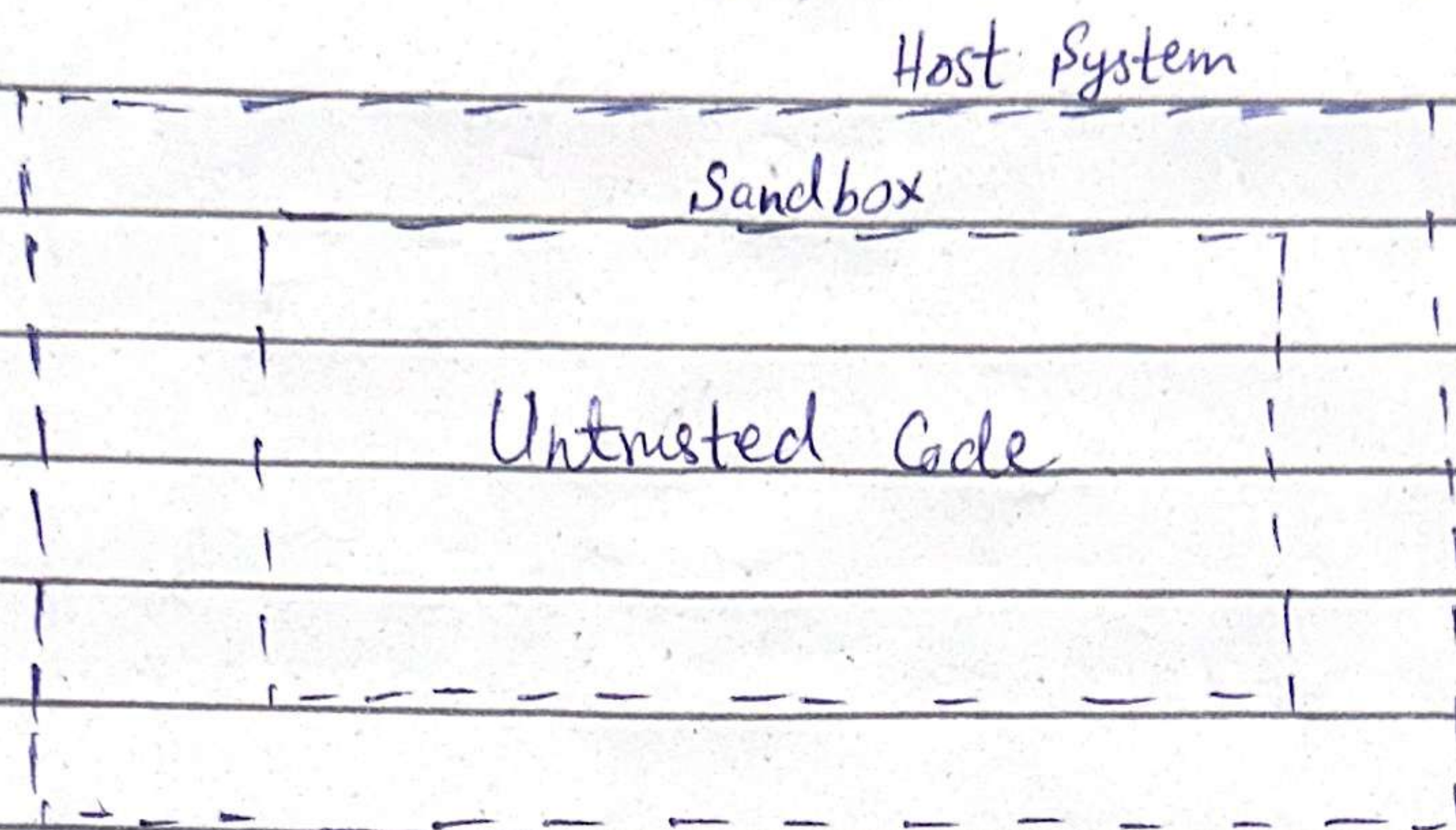
- i) limiting permissions using RBAC.
- ii) Keeping audit logs.
- iii) Regular security check.

(17)

Wireless networks use access control to stop unauthorized devices. Security methods include WPA2, WPA3, passwords and authentication servers. MAC address filtering can allow only known devices. Network access control check device before allowing connection. This prevents rogue devices from entering the network.

DATE: / /

(18)



Untrusted Code runs inside sandbox.

(19)

Threat	Description	Impact
Weak Password	Easy to guess	High
Privilege Abuse	User misuses access	High
Misconfiguration	Wrong permissions	High
Insider Attack	Employee misuse	High
PHISHING	Stealing login	Medium

(20)

If roles overlap, user may get more access than needed, This can cause security problems. The solution is role review and removing extra permissions. Organizations should follow least privilege rule to

avoid conflicts.

{Section C}

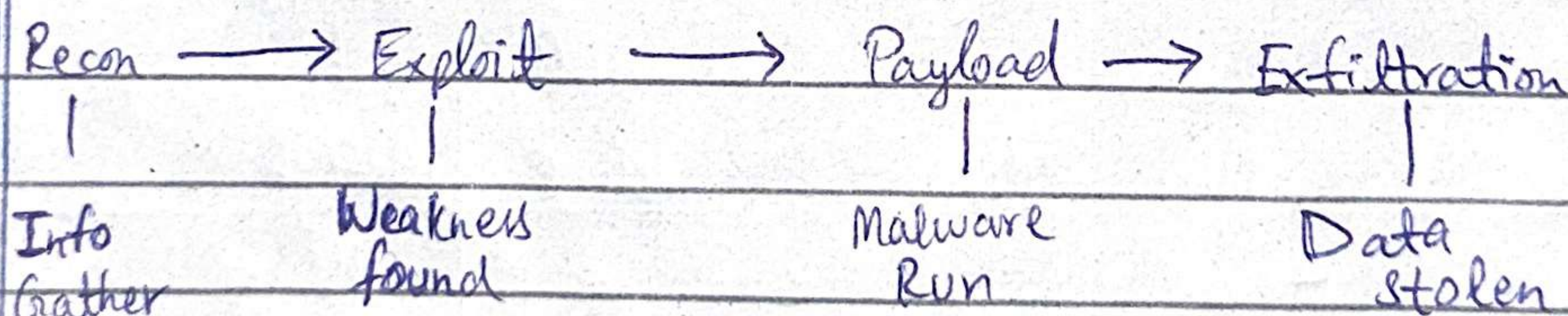
(21)

- i) Malware is harmful software that damages systems.
- ii) Virus attaches to files and spreads when file runs.
- iii) Worms spread automatically through networks.
- iv) Trojan looks safe but installs malware.
- v) Ransomware locks files and asks for money.

Prevention includes:

- i) Antivirus
- ii) Latest Updates
- iii) Safe browsing.

(22)



Security:

Firewall → Patch → Antivirus → Monitoring.

(23)

Threats to business can come from inside or outside.

Internal Threats: Employee ~~set~~ stealing data or misusing access.

External Threats: Hackers, malwares, and phishing attacks

Both can damage company data & reputation.

(24)

Attack Vector	Prevention
PHISHING	User Training
Malware	Antivirus
Network attack	Firewall
Weak password	MFA
Data Theft.	Encryption

(25)

Softwares may have bugs that attacker can use. Common problems include weak validation, less ~~code~~ access control practices, and outdated software.

Preventions include:

i) Patching: Fixing code/bugs.

ii) Secure Coding: Using best code practices.

iii) Code Review: Reviewing code to see potential issues.

Regular updates keep system secure.

(26)

Threats:

- i) Unauthorized access
- ii) SQL injection
- iii) Data theft.

Prevention techniques:

- i) Encryption: Store encrypted data.
- ii) Least privilege ~~uses~~ gives users limited access.
- iii) Auditing tracks who accessed data.

(27)

Privacy protects user identity online.

Differential policy hides personal data in statistics.

Tor network hides user location.

Pseudonyms allow users to use fake names.

These methods help keep users safe on internet.

(28)

Ransomware: It encrypts company files and asks for payment. It may enter through email attachment or weak security.

- Prevention
- Vulnerability includes backup, antivirus and training.
- Vulnerability ^{may} includes no antivirus or outdated system

DATE: _/_/

⇒ Response includes isolating systems and restoring backup.

(29)

Security policy defines rules for protecting systems. Organizations use standards like COBIT and ISO 27001.

These help manage risks and control access. Attack prevention tools must follow policy. Good governance improves overall security.

(30)

